

Fundamentals of Information Systems Security

PCI DSS v3.2.1 Quick Reference Guide

Payment Card Industry Data Security Standard Requirements

Version: 3.2.1

Publication Date: May 2018

Status: Current

Requirements: 12

Contents

1	Introduction to PCI DSS	2
1.1	Overview	2
1.2	Purpose and Scope	2
1.3	Key Concepts	2
2	The Six Goals and Twelve Requirements	3
3	Detailed Requirements	4
3.1	Goal 1: Build and Maintain a Secure Network	4
3.1.1	Requirement 1: Install and Maintain Firewall Configurations	4
3.1.2	Requirement 2: Do Not Use Vendor-Supplied Defaults	4
3.2	Goal 2: Protect Cardholder Data	4
3.2.1	Requirement 3: Protect Stored Cardholder Data	4
3.2.2	Requirement 4: Encrypt Transmission of Cardholder Data	4
3.3	Goal 3: Maintain a Vulnerability Management Program	5
3.3.1	Requirement 5: Protect All Systems Against Malware	5
3.3.2	Requirement 6: Develop and Maintain Secure Systems	5
3.4	Goal 4: Implement Strong Access Control Measures	5
3.4.1	Requirement 7: Restrict Access by Business Need-to-Know	5
3.4.2	Requirement 8: Identify and Authenticate Access	5
3.4.3	Requirement 9: Restrict Physical Access	6
3.5	Goal 5: Regularly Monitor and Test Networks	6
3.5.1	Requirement 10: Track and Monitor Access	6
3.5.2	Requirement 11: Regularly Test Security Systems	6
3.6	Goal 6: Maintain an Information Security Policy	6
3.6.1	Requirement 12: Support Information Security with Policies	6
4	Compliance Validation	7
4.1	Validation Requirements	7
4.2	Key Compliance Activities	7
5	Common Pitfalls and Best Practices	7
5.1	Common Pitfalls	7
5.2	Best Practices	7
6	References	8

1 Introduction to PCI DSS

1.1 Overview

The Payment Card Industry Data Security Standard (PCI DSS) is a set of security standards designed to ensure that all organizations that accept, process, store, or transmit credit card information maintain a secure environment[reference:102]. The standard was developed by the PCI Security Standards Council, which includes major credit card brands.

1.2 Purpose and Scope

The primary purpose of PCI DSS is to[reference:103]:

- Protect cardholder data (CHD) from security breaches
- Reduce the risk of credit card fraud
- Establish a baseline of security practices for payment card processing
- Ensure all organizations maintain a secure environment for cardholder data

1.3 Key Concepts

Key Definitions

- **Cardholder Data (CHD):** Full PAN (primary account number), cardholder name, expiration date, and service code
- **Sensitive Authentication Data:** Full track data, CAV2/CVC2/CVV2/CID, PINs/PIN blocks
- **PCI DSS Scope:** All systems, networks, and people that store, process, or transmit cardholder data

2 The Six Goals and Twelve Requirements

PCI DSS v3.2.1 comprises 12 requirements, grouped into six goals[reference:104][reference:105]:

Goal	Requirement	Description
Build and Maintain a Secure Network	1-2	Install and maintain firewall configurations and secure systems
Protect Cardholder Data	3-4	Protect stored cardholder data and encrypt transmission
Maintain a Vulnerability Management Program	5-6	Protect against malware and develop secure applications
Implement Strong Access Control Measures	7-9	Restrict access to cardholder data by business need-to-know
Regularly Monitor and Test Networks	10-11	Track and monitor all access to cardholder data and test security systems
Maintain an Information Security Policy	12	Maintain a policy that addresses information security for all personnel

3 Detailed Requirements

3.1 Goal 1: Build and Maintain a Secure Network

3.1.1 Requirement 1: Install and Maintain Firewall Configurations

Install and maintain a firewall configuration to protect cardholder data[reference:106][reference:107].

Key Points

- Establish firewall and router configuration standards
- Build a firewall configuration that restricts connections between untrusted networks and any system in the cardholder data environment
- Prohibit direct public access between the Internet and any system in the cardholder data environment
- Install personal firewall software on any mobile or employee-owned devices with access to the CDE

3.1.2 Requirement 2: Do Not Use Vendor-Supplied Defaults

Do not use vendor-supplied defaults for system passwords and other security parameters[reference:108].

- Always change vendor-supplied defaults before installing a system
- Develop configuration standards for all system components
- Encrypt all non-console administrative access
- Remove unnecessary functionality and services

3.2 Goal 2: Protect Cardholder Data

3.2.1 Requirement 3: Protect Stored Cardholder Data

Protect any stored cardholder data[reference:109].

- Keep cardholder data storage to a minimum
- Do not store sensitive authentication data after authorization
- Mask PAN when displayed (first six and last four digits)
- Render PAN unreadable anywhere it is stored using encryption, hashing, truncation, or tokenization
- Document and implement procedures for protecting stored cardholder data

3.2.2 Requirement 4: Encrypt Transmission of Cardholder Data

Encrypt cardholder data for secure transmission across open, public networks[reference:110].

- Use strong cryptography and security protocols (e.g., TLS 1.2 or higher)
- Do not send unprotected PANs by end-user messaging technologies
- Ensure wireless networks transmitting cardholder data use strong encryption

3.3 Goal 3: Maintain a Vulnerability Management Program

3.3.1 Requirement 5: Protect All Systems Against Malware

Protect all systems against malware and regularly update anti-virus software or programs.

- Deploy anti-virus software on all systems commonly affected by malware
- Ensure anti-virus programs are capable of detecting, removing, and protecting against all known types of malware
- Keep anti-virus software current, active, and capable of generating audit logs

3.3.2 Requirement 6: Develop and Maintain Secure Systems

Develop and maintain secure systems and applications[reference:111].

- Establish a process to identify and assign a risk ranking to newly discovered security vulnerabilities
- Protect all system components and software from known vulnerabilities by installing applicable vendor-supplied security patches
- Develop software applications in accordance with PCI DSS and industry best practices
- Address common coding vulnerabilities
- Change vendor-supplied defaults for application passwords and other security parameters

3.4 Goal 4: Implement Strong Access Control Measures

3.4.1 Requirement 7: Restrict Access by Business Need-to-Know

Restrict access to cardholder data by business need-to-know.

- Limit access to system components and cardholder data to only those individuals whose job requires such access
- Establish an access control system for systems components with multiple users
- Restrict access to privileged user IDs to least privileges necessary

3.4.2 Requirement 8: Identify and Authenticate Access

Identify and authenticate access to system components.

- Define and implement policies and procedures for user identification and authentication
- Assign a unique ID to each person with computer access
- Implement multi-factor authentication for all non-console access into the CDE
- Ensure proper user authentication and password management
- Lock out users after no more than six attempts

3.4.3 Requirement 9: Restrict Physical Access

Restrict physical access to cardholder data.

- Use appropriate facility entry controls to limit and monitor physical access to systems
- Protect physical access to media containing cardholder data
- Maintain a log of all physical access
- Implement procedures for secure disposal of media

3.5 Goal 5: Regularly Monitor and Test Networks

3.5.1 Requirement 10: Track and Monitor Access

Track and monitor all access to network resources and cardholder data.

- Implement audit trails to link all access to system components to individual users
- Implement automated audit trails for all system components
- Record at least the following: user identification, type of event, date and time, success or failure indication, origination of event, identity of affected data
- Protect audit trails from unauthorized access
- Retain audit trail history for at least one year
- Review logs for all system components at least daily

3.5.2 Requirement 11: Regularly Test Security Systems

Regularly test security systems and processes.

- Implement processes to test for the presence of wireless access points (WAPs)
- Run internal and external vulnerability scans at least quarterly
- Perform penetration testing at least annually
- Deploy file-integrity monitoring tools to alert personnel to unauthorized modification of critical system files

3.6 Goal 6: Maintain an Information Security Policy

3.6.1 Requirement 12: Support Information Security with Policies

Maintain a policy that addresses information security for all personnel[reference:112].

- Establish, publish, maintain, and disseminate a security policy
- Conduct risk assessments at least annually
- Develop usage policies for critical technologies
- Implement a formal security awareness program
- Screen potential employees prior to hire
- Maintain and implement policies and procedures to manage service providers
- Conduct annual reviews to roll out necessary updates, especially after significant changes to the CHD environment[reference:113]

4 Compliance Validation

4.1 Validation Requirements

PCI DSS compliance validation requirements vary based on the volume of transactions:

Level	Transaction Volume	Validation Requirements
Level 1	Over 6 million transactions/year	Annual On-Site Assessment + Quarterly ASV Scan
Level 2	1-6 million transactions/year	Annual Self-Assessment Questionnaire + Quarterly ASV Scan
Level 3	20,000-1 million e-commerce transactions	Annual Self-Assessment Questionnaire + Quarterly ASV Scan
Level 4	Less than 20,000 e-commerce transactions	Annual Self-Assessment Questionnaire + Quarterly ASV Scan

4.2 Key Compliance Activities

1. **Self-Assessment Questionnaire (SAQ):** Complete the appropriate SAQ based on your business model
2. **Vulnerability Scanning:** Conduct quarterly external vulnerability scans by an Approved Scanning Vendor (ASV)
3. **Penetration Testing:** Conduct annual internal and external penetration testing
4. **Compliance Reporting:** Submit compliance reports to acquiring banks

5 Common Pitfalls and Best Practices

5.1 Common Pitfalls

- Failing to maintain a current inventory of all systems in the CDE
- Insufficient scope reduction (PCI DSS scope creep)
- Incomplete or inaccurate documentation
- Neglecting to review logs and security alerts
- Using outdated cryptographic protocols
- Inadequate third-party vendor management

5.2 Best Practices

- Implement a comprehensive asset inventory
- Regularly review and update PCI DSS scope
- Conduct regular risk assessments
- Implement continuous monitoring

- Use tokenization and encryption to reduce scope
- Provide regular security awareness training
- Maintain robust incident response procedures

6 References

- PCI Data Security Standard v3.2.1 (May 2018)
- PCI DSS Quick Reference Guide
- PCI DSS Self-Assessment Questionnaire Instructions and Guidelines
- PCI DSS Prioritized Approach
- PCI DSS Glossary of Terms, Abbreviations, and Acronyms